

Security at AI Speed — For the CEO

1. Why This Matters to You

Your exposure is no longer defined by control gaps. It is defined by how long your organisation takes to **see, decide, authorise, and act** once an attack is in motion. In a machine-speed environment, decision latency becomes business consequence — operational disruption, regulatory exposure, loss of customer trust, and material impact on continuity and earnings. The attacker does not wait for your committees to align. The competitors who have already made the hard trade-offs will recover faster than you when — not if — the event arrives. These are no longer decisions you can delegate to your CISO and review quarterly. The choices that determine how your business survives an attack are **business decisions**, and they belong to you.

2. The Core Problem

Most enterprises still run a security model built for a slower world: detect, escalate, validate, discuss, approve, act. That sequence is now obsolete. Attackers compress reconnaissance, access, lateral movement, and exfiltration into a single motion that completes before human coordination catches up. Periodic governance — quarterly reviews, annual audits, exception registers — describes risk *after* exposure has already drifted. The illusion of control coverage (more frameworks, more products, more programs) masks the real failure: **authority is not pre-positioned, trade-offs are not pre-decided, and accountability is diffused into a function that cannot, in fact, own the consequence.** Your security programme may look mature in reports and still be operationally obsolete.

3. What You Must Own

- **The statement "we will not protect everything equally."** Until you legitimise it publicly, your organisation cannot prioritise. Investment stays diffuse. Recovery stays incoherent. This sentence is the gate to every serious decision behind it.
- **Acceptable loss.** Which services must survive, which may degrade, which may be lost. This is a CEO statement, not a CISO recommendation. Recovery Time Objective (RTO) and Recovery Point Objective (RPO) must be **executable under realistic conditions**, not aspirational numbers in a plan you have never tested.
- **Pre-authorization of operational disruption.** Which identities can be suspended, which assets isolated, which workflows interrupted, which services degraded — signed off **before** the event, not improvised during it. If you do not pre-commit, your Security Operation Center (SOC) will improvise on your behalf, with worse evidence and no mandate.
- **Consequence ownership in the business.** The convenient fiction that the CISO "owns" cyber risk ends here. Accountable leaders own consequence in their domains. The CISO equips them to decide — and to live with the decision publicly.
- **One operational truth of your digital estate.** Not the CISO's view, the COO's view, and the auditor's view. One live picture of what matters, how it is connected, and where it is exposed. You cannot govern fragments.

4. What Must Change Now

- **From review to decision.** Governance stops being a periodic reporting cadence. It becomes a

continuous decision loop tied to live exposure, with time-boxed outputs measured in days and weeks, not quarters - and is a threat-led risk management process.

- **From escalation to pre-authorization.** Containment actions execute against thresholds you have already approved. Escalation informs you; it does not block action.
- **From "everything is critical" to **named crown jewels**.** Specific business services, specific data classes, specific dependencies — defined in operational terms, with disruption and loss thresholds you have signed.
- **From CISO owning risk to accountable leaders owning consequence.** Risk decisions sit with the executives whose domains carry the loss. The CISO is the function that makes those decisions possible, not the buffer that absorbs them.
- **From assurance through process to assurance through execution.** Your audit and risk functions stop confirming that documents exist and start testing whether your stated decisions remain executable when time is compressed.

5. The One Question to Take Into Your Next Executive Meeting

"If we were under active attack right now, which of my executives has the authority to disrupt this business to contain it — and which of them has already accepted, in writing, what we are willing to lose?"

If you cannot name them by Monday, you do not have a security model. You have an aspiration.